

Ameaças, Vulnerabilidades e Risco

Objetivo da Aula

Apresentar os conceitos de ameaça, vulnerabilidade e risco, Além de outros conceitos envolvidos, como os de ativo da informação, disponibilidade, confidencialidade, integridade, autenticidade e não repúdio.

Apresentação

Todos os dias vemos notícias informando que alguma empresa ou governo teve seu site invadido, seu funcionamento afetado e seus dados sequestrados ou evadidos, sem contar os inúmeros golpes direcionados às pessoas físicas com o objetivo de obter informações pessoais e aplicar fraudes financeiras. Nesta aula, você aprenderá os conceitos básicos sobre segurança da informação, que servirão de base para entender como mitigar os riscos e proteger a si próprio e a organização onde trabalha.

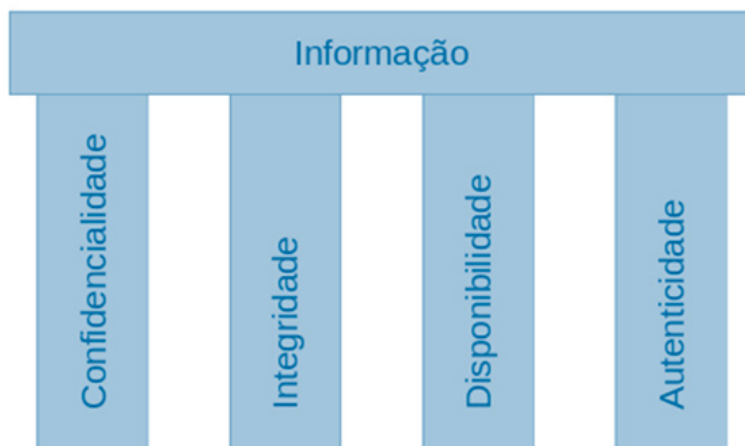
1. Conceitos Básicos de Segurança da Informação

1.1. Ativo de Informação

Um ativo de informação é qualquer elemento que manipule, transporte, armazene ou descarte uma informação, incluindo ela própria. Logo, um cabo de rede, um servidor de banco de dados, um roteador ou um usuário, além da própria informação, podem ser classificados como um ativo de informação.

1.2. Pilares da Informação

Quando dizemos que um ativo de informação é comprometido, é porque uma das propriedades da informação foi comprometida. A figura 1 apresenta os quatro pilares da informação.

Figura 1: Quatro pilares da informação

Fonte: elaboração própria (2023).

- **Confidencialidade** – garante que uma informação só pode ser acessada por quem tenha permissão de fazê-lo.
- **Integridade** – garante que uma informação só pode ser alterada por quem tenha permissão de fazê-lo.
- **Disponibilidade** – garante que a informação esteja disponível sempre que necessário.
- **Autenticidade (não repúdio)** – garante que a origem da informação não pode ser contestada.

2. Ameaças

Para a segurança da informação, uma ameaça é tudo que pode explorar uma vulnerabilidade, comprometendo um ativo de informação. As ameaças podem ser externas ou internas, naturais ou provocadas – propositais ou acidentais. O quadro 1 apresenta algumas das principais ameaças em TI.

Quadro 1: Principais ameaças à segurança de uma rede

Malwares	Contêm software ou código malicioso em execução no dispositivo do usuário.
Spyware e adware	São softwares instalados no dispositivo do usuário para coletar, secretamente, informações sobre o usuário.
Ataques de dia zero (Zero-Day)	Também chamados de ataques de hora zero, ocorrem no primeiro dia em que uma vulnerabilidade é descoberta.
Ataques de negação de serviço (Deny of Service – DoS)	Esses ataques atrasam ou travam aplicativos e processos em um dispositivo de rede.
Ataques de negação de serviço distribuído (Deny of Service – DoS)	Idênticos ao DoS, porém com partindo de várias origens.
Sequestro ou roubo de dados	Esse ataque captura ou indisponibiliza (por criptografia) informações privadas da rede de uma organização.
Roubo de identidade	Esse ataque rouba as credenciais de login de um usuário para acessar informações privadas.
Engenharia Social	Uso de técnicas para enganar os usuários com o objetivo de ganhar acesso a rede e a dados confidenciais.

Fonte: elaboração própria (2023).

2.1. Malwares

Malware é um software malicioso, projetado especificamente para danificar, interromper, roubar ou infligir ações disruptivas ou ilegítimas em dados, hosts ou redes. Vejamos os principais tipos de Malware:

- **Vírus** – um vírus de computador é um programa que se replica inserindo uma cópia de si mesmo dentro de outro programa e tornando-se parte dele, sempre que o programa hospedeiro (normalmente um executável ou arquivo de macro) é executado. Os vírus se propagam quando o software ou documento no qual estão inseridos é transferido de um computador para outro usando a rede, via compartilhamento de arquivos, pen drives ou anexos de e-mail infectados.
- **Worms** – os worms são parecidos com os vírus, mas sua reprodução é independente de outros programas, eles não necessitam de um hospedeiro ou ajuda humana para se propagar, pois utilizam os recursos do sistema para viajar pela rede sem necessariamente a ajuda de uma vulnerabilidade no sistema para se instalar.
- **Cavalos de Troia (Trojan)** – um cavalo de Troia é um tipo de malware, um software que parece legítimo, mas traz dentro de si um software malicioso. Os usuários são ludibriados executando-os em seus sistemas, que depois de ativados, podem causar vários ataques ao host. Cavalos de Troia também são conhecidos por criarem portas

dos fundos (back doors) que permitem o acesso de usuários mal-intencionados ao sistema. Os cavalos de Troia se espalham pela interação do usuário, como abrir um anexo de e-mail ou fazer o download e executar um arquivo da Internet.



Você Sabia?

Este malware recebeu seu nome do cavalo de madeira usado pelos gregos para invadir a cidade de Troia, no épico “A Ilíada”, de Homero. Deixado na porta da cidade como um presente à vitória dos troianos, trazia dentro de si vários soldados, que durante a noite abriram as portas da cidade para a entrada dos gregos.

2.2. Ataque à Infraestrutura da Rede e Serviços

Estes ataques são efetuados diretamente às configurações e infraestrutura dos serviços de rede. O objetivo é desabilitar o serviço ou explorar as vulnerabilidades do sistema operacional ou dos servidores, como, por exemplo, uma configuração padrão ou do acesso ao sistema de arquivos do servidor.

2.3. Ataques ao Código da Aplicação

Ataque ao código da aplicação são os ataques da moda, estes ataques exploram vulnerabilidades no código da aplicação devido falhas ou a não observância de boas práticas de programação.

2.4. Segurança Física

Um outro aspecto que deve ser considerado é a segurança física. Caso os recursos de rede possam ser fisicamente comprometidos, uma ameaça poderá negar o uso de recursos de rede. As quatro classes de ameaças físicas são as seguintes:

- **Ameaças de hardware** – inclui ataques físicos a servidores, roteadores, switches, instalações de cabeamento e estações de trabalho.
- **Ameaças ambientais** – ligadas a fatores externos como temperatura (muito quente ou muito frio) ou umidade (muito úmido ou muito seco).
- **Ameaças elétricas** – inclui picos de tensão, tensão de alimentação insuficiente (quedas de energia), energia não condicionada (ruído) e perda total de energia.

- **Ameaças à manutenção** – inclui a manipulação de componentes elétricos (descarga eletrostática), falta de peças de reposição críticas, cabeamento incorreto e rotulagem inadequada.

2.5. Atores de Ameaças

Um ator de ameaça é alguém capaz de manipular vetores de ameaça com o objetivo de explorar as vulnerabilidades de uma organização ou pessoa. São comumente chamados de hacker. O quadro 2 apresenta as nomenclaturas mais utilizadas para designar os diversos atores de ameaças (hackers), atualmente.

Quadro 2: Nomenclatura para os autores de ameaças

Nomenclatura	Descrição
Script Kiddies	São pessoas com pouca ou nenhuma habilidade, que costumam usar ferramentas (exploits) encontradas na Internet para lançar ataques. Mesmo que eles estejam usando ferramentas básicas, os resultados ainda podem ser devastadores para organizações, governo e pessoas.
Hackers de chapéu branco – White Hat (Hacker Ético)	São aqueles que usam suas habilidades de programação para propósitos éticos e legais, atuam na realização de testes de penetração de rede a fim de descobrir vulnerabilidades e relatá-las aos desenvolvedores e administradores para que possam ser corrigidas.
Hackers de chapéu cinza – Grey Hat ()	São indivíduos que cometem crimes cibernéticos e agem de forma antiética, mas não para ganho pessoal ou para causar danos. Os hackers de chapéu cinza podem revelar uma vulnerabilidade à organização afetada após terem comprometido sua rede.
Hacktivistas	Hacktivistas são hackers que protestam contra uma variedade de ideias políticas e sociais, focam suas ações contra organizações ou governos postando artigos e vídeos, vazando informações confidenciais e interrompendo serviços da web com tráfego ilegítimo em ataques de negação de serviço distribuída (DDoS).
Hackers de chapéu preto – Black hat – Cracker (Cibercriminal)	Esses são criminosos antiéticos que comprometem a segurança do computador e da rede para ganho pessoal ou por motivos maliciosos, como ganhos financeiros e ações terroristas.

Fonte: elaboração própria (2023).



Você Sabia?

O termo hacker originalmente descrevia um especialista com profundos conhecimentos de tecnologia capaz de resolver a maioria dos problemas a ele submetidos, porém, com a evolução do uso de computadores e o crescimento das ameaças, evoluiu para o significado que conhecemos hoje em dia.

3. Vulnerabilidades

Vulnerabilidades são fraquezas nos processos, nas tecnologias e nas pessoas e que podem ser exploradas pelas ameaças.

- **Vulnerabilidades de processo** – estão associadas aos procedimentos administrativos na rede e nos sistemas, estão normalmente relacionadas à falta uma política de segurança formalmente estabelecida e comunicada, que defina claramente como devem ser tratadas senhas de acesso, periodicidade de troca, inclusão e exclusão de usuário na rede e nos sistemas, além de estabelecer um plano de continuidade de negócios e recuperação de desastres.
- **Vulnerabilidades tecnológicas** – estão associadas a deficiências nos protocolos, sistemas operacionais e no hardware dos equipamentos ou nas aplicações devido a não observância de boas práticas de programação, na construção delas. Também diz respeito a problemas de configuração tanto dos sistemas e aplicações como na aplicação das políticas de segurança às contas de usuário, por exemplo.
- **Vulnerabilidades das pessoas** – é o elo mais fraco da cadeia de segurança, usuários mal treinados podem comprometer seriamente a segurança vazando dados confidenciais, sendo alvo fácil da engenharia social ou atuando de forma mal-intencionada.

4. Risco

Podemos dizer que, em segurança da informação, risco é a probabilidade de uma ameaça explorar uma vulnerabilidade e causar um determinado impacto. Quanto maior a probabilidade e maior o impacto, maior o risco. O impacto é a estimativa da medida do dano causado se uma ameaça conseguir explorar uma determinada vulnerabilidade.

Um mapa de risco é o resultado da análise de vulnerabilidade, da probabilidade de ataque e dos impactos que uma determinada organização está exposta num dado momento. A figura 2 apresenta um exemplo hipotético de mapa de risco.

Figura 2: Mapa de riscos



Fonte: elaboração própria (2023).

Dependendo do risco, pode-se tomar as seguintes ações em relação a ele:

- **Evitar** – visa evitar completamente que este risco ocorra, através de ações para levar a probabilidade do risco a zero, por exemplo, desligando um servidor vulnerável.
- **Transferir** – transfere para terceiros o ônus do risco, por exemplo, fazendo um seguro, ou através de cláusulas contratuais. A transferência não elimina nem diminui o risco.
- **Mitigar** – visa reduzir a probabilidade da ocorrência ou o impacto de um risco a um nível aceitável. Exemplo: tomar medidas de segurança ou prever sistemas ou recursos redundantes.
- **Aceitar** – significa aceitar os riscos sem tomar nenhuma providência ou estabelecer um plano de contingência caso o risco ocorra. Isso normalmente é feito quando a probabilidade de ocorrência e o impacto são baixos ou quando o custo de mitigar ou transferir o risco é muito maior que o valor do ativo. Por exemplo, não fazer seguro de um carro de valor muito baixo.

Considerações Finais da Aula

Você viu que, atualmente, as ameaças estão em todo lugar, como o vazamento de dados em empresas de cartões de crédito ou sites governamentais expondo informações

de milhares ou até mesmo tirando do ar sites de prefeituras ou empresas. Além disso, a cada dia novas ameaças surgem, dados das empresas são sequestrados pelos ransomware, causando prejuízos enormes, sejam financeiros como de imagem.

As organizações procuram avaliar as ameaças a que estão expostas e suas vulnerabilidades e os impactos, a fim de analisar os riscos e criar estratégias de como lidar com estes riscos.

Material Complementar



Cartilha de Segurança na Internet – CERT.BR

O CERT.br é um CSIRT Nacional de Último Recurso, mantido pelo NIC.br, e presta serviços da área de Gestão de Incidentes de Segurança da Informação para qualquer rede que utilize recursos administrados pelo NIC.br. Nessa cartilha, você pode se aprofundar mais sobre os aspectos básicos de segurança e conhecer a estrutura de segurança da internet no Brasil.

Link para acesso: <https://www.cert.br/>

Referências

BARRETO, Jeanine dos Santos *et al.* **Fundamentos de segurança da informação**. Porto Alegre: SAGAH, 2018.

COMER, Douglas E. **Redes de computadores e internet**. 6. ed. Porto Alegre: Bookman, 2016.

FOROUZAN, Behrouz A.; MOSHARRAF, Firouz. **Redes de computadores: uma abordagem top-down**. 1. ed. Porto Alegre: AMGH, 2013.

LACERDA, Paulo Sérgio Pádua de *et al.* **Projeto de redes de computadores**. Porto Alegre: SAGAH, 2022.

MAIA, Luiz Paulo. **Arquitetura de redes de computadores**. 2. ed. Rio de Janeiro: LTC, 2013.

MORAES, Alexandre Fernandes de. **Segurança em redes: fundamentos**. São Paulo: Erica, 2010.

NETWORK ACADEMY. **Introduction to Networks (CCNAv7)**. Disponível em: <https://www.netacad.com>. Acesso em: 3 jun. 2023.

SOUSA, Lindeberg Barros de. **Redes de computadores: guia total**. 1. ed. São Paulo: Erica, 2009.

_____. **Administração de redes locais**. 2. ed. São Paulo: Erica, 2020.